

מודול 6 — סריקה, מיפוי והערכת חולשות

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 6 — סריקה, מיפוי והערכת חולשות (Scanning & Enumeration)

הכול בגלילה אחת: כל החומר של המודול בקובץ אחד — חומר לימוד, תרגילים, תרגול ופתרונות, ברצף.

🎬 מודול מעשי! אחרי כל נושא — “הדגמה — נסה בעצמך”. תסרוק מטרה רב-שירותית (`scan_target.py`, בלי התקנות) עם `nmap`, תתפוס Banner-ים ותגלה גרסאות פגיעות (כמו `vsFTPD 2.3.4` המפורסם), תריץ Directory Brute-Force על אתר, ותחבר גרסה ל-`searchsploit`. אחרי כל הדגמה: 🧠 בדוק את עצמך.

מודול 6 — סריקה, מיפוי והערכת חולשות (Scanning & Enumeration)

מטרות המודול: לעבור מ-Recon פסיבי לסריקה אקטיבית — לשלוט ב-Nmap לעומק, למנות שירותים (HTTP/HTTPS, SMB, SSH, FTP), להריץ סריקת חולשות עם **Nessus**, ולחקור חולשות עם **Searchsploit / Exploit-DB**. זהו השלב שממפה את משטח התקיפה ומזהה את נקודות הכניסה.

קבצים: `slides.md` · `practice.md` · `solutions.md` · `missions.md` · `README.md`

מבוסס על שיעורי המקור #39–#47 (Kioptrix + Nmap, Enumerating HTTP/SMB/SSH, Researching) (Vulnerabilities, Nessus).

המקום בשרשרת: שלב 2 מחמשת השלבים. אחרי שמיפינו את היעד (מודול 5), עכשיו נוגעים בו ישירות — מוצאים פורטים, שירותים, גרסאות וחולשות. ככל שהמנייה יסודית יותר, כך הניצול (מודול 7) קל יותר.

תוכן העניינים

1. שלב הסריקה — סקירה
2. Nmap — יסודות וגילוי מארחים
3. Nmap לעומק
4. מניית HTTP/HTTPS
5. מניית SMB
6. מניית SSH ו-FTP
7. סריקת חולשות עם Nessus

6.1 שלב הסריקה — סקירה

בעוד Recon פסיבי נמנע ממגע, הסריקה היא **אקטיבית** — שולחים חבילות ליעד ומנתחים את התגובות. שני מושגים: **Scanning** — מציאת מכונות חיות ופורטים פתוחים. - **Enumeration (מנייה)** — חפירה עמוקה בכל שירות שנמצא: גרסה, הגדרות, משתמשים, שיתופים, ספריות.

💡 **כלל הזהב של המנייה:** “90% *Enumerate, enumerate, enumerate*” מהעבודה כאן. כל פורט פתוח = שירות = חולשה פוטנציאלית. אל תמהר לניצול לפני מנייה יסודית.

מכונת התרגול בקורס: Kioptrix Level 1 (מ-VulnHub) — מכונה פגיעה בכוונה, מצוינת לתרגול. הורד, טען ב-VirtualBox (או VMware) באותה רשת (Host-Only) כמו Kali.

6.2 Nmap — יסודות וגילוי מארחים

Nmap (Network Mapper) הוא הכלי המרכזי לסריקה. נתחיל ב**גילוי מארחים** (מי חי ברשת):

```
nmap -sn 192.168.56.0/24 # Host Discovery בלבד (ping sweep), ללא סריקת פורטים
```

סריקת פורטים בסיסית על יעד:

```
nmap 192.168.56.10 # הפורטים הנפוצים 1000
nmap -p- 192.168.56.10 # כל 65,535 הפורטים (איטי אך יסודי)
nmap -p 80,443,445 192.168.56.10 # פורטים ספציפיים
nmap -F 192.168.56.10 # מהיר (100 פורטים)
```

סוגי סריקה עיקריים

דגל	סוג	הערה
-sS	SYN Scan	ברירת מחדל (דורש root), מהיר ו"חצי-פתוח"
-sT	TCP Connect	לחיצת יד מלאה (ללא root)
-sU	UDP Scan	לשירותי UDP (DNS, SNMP), איטי
-sn	ללא סריקת פורטים	גילוי מארחים בלבד

 **קשר למודול 3: -sS** - שולח SYN ומנתח את התשובה (SYN-ACK=פתוח, RST=סגור) — בדיוק מנגנון לחיצת היד שלמדנו.

 הדגמה — נסה בעצמך: סרוק מטרה אמיתית עם Nmap

נפעיל מטרה עם 4 שירותים, ונמצא אותם עם nmap — בדיוק כמו על מכונת Kioptrix.

צעד 1 — טרמינל 1: הפעל את המטרה (scan_target.py):

```
python3 scan_target.py
```

 נפתחים 4 פורטים: 2121, 2222, 8080, 10000. **השאר רץ.**

צעד 2 — טרמינל 2: גילוי מארחים חיים ברשת:

```
nmap -sn 127.0.0.1 # האם היעד חי?
```

צעד 3 — סרוק את הפורטים:

```
nmap 127.0.0.1 -p 2121,2222,8080,10000
```

 כל ארבעתם open . **מצאת את משטח התקיפה.**

 **מה קרה כאן:** nmap ניסה לחיצת-יד לכל פורט; SYN-ACK = פתוח. עכשיו יש לך רשימת שירותים למנות — הצעד הבא.

 **בדוק את עצמך:** מה עושה nmap -sn ? (א) סורק את כל 65,535 הפורטים - (ב) גילוי מארחים חיים בלבד, **בלי** סריקת פורטים - (ג) מזהה מערכת הפעלה

✓ **תשובה: ב** — `-sn` (no port scan) רק בודק מי חי ברשת. זהו הצעד הראשון לפני שסורקים פורטים.

Nmap 6.3 לעומק — שירותים, גרסאות ו-NSE

מציאת פורט פתוח היא רק ההתחלה. עכשיו מְמַנִּים אותו:

```
nmap -sV 192.168.56.10      # Version Detection – גרסאות השירותים
nmap -O 192.168.56.10      # Operating System detection
nmap -sC 192.168.56.10     # סקריפטים ברירת מחדל (NSE)
nmap -A 192.168.56.10     # -sV -O -sC + traceroute: אגרסיבי
```

הסריקה המומלצת להתחלה (משלב הכל):

```
nmap -sC -sV -oN scan.txt 192.168.56.10
```

• `-sC` סקריפטים · `-sV` גרסאות · `-oN scan.txt` שמירת פלט לקובץ.

דוגמת פלט וקריאתה

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 2.9p2 (protocol 1.99)
80/tcp	open	http	Apache httpd 1.3.20 ((Unix) mod_ssl/2.8.4)
139/tcp	open	netbios-ssn	Samba smbd
443/tcp	open	ssl/http	Apache/1.3.20

כל שורה = יעד פוטנציאלי. שים לב ל**גרסאות הישנות** (OpenSSH 2.9, Apache 1.3.20) — אלה מובילים לחולשות ידועות (סעיף 6.8).

🎬 הדגמה — נסה בעצמך: תפוס Banner וגלה גרסה

מציאת פורט פתוח זה כלום — הזהב הוא ה**גרסה**. נחלץ אותה בשתי דרכים.

דרך 1 — nmap עם זיהוי גרסאות (מול `scan_target.py` שרץ):

```
nmap 127.0.0.1 -p 2121,2222,8080,10000 -sV
```

👁️ nmap מציג את ה-Banner של כל שירות, כולל `vsftpd 2.3.4` ו-`OpenSSH 2.9`.

דרך 2 — “תפיסת Banner ידנית עם netcat” (מתחברים וקוראים מה שהשירות “אומר”):

```
nc 127.0.0.1 2121      # FTP → 220 (vsFTPD 2.3.4)
nc 127.0.0.1 2222      # SSH → SSH-2.0-OpenSSH_2.9p2
nc 127.0.0.1 10000     # ? → flag{enumerate_every_open_port}
```

```
python3 -c "import socket; s=socket.socket(); s.connect(('127.0.0.1',2121)); print(s.recv(100).decode())"
```

👁️ הפורט 10000 נראה “משעמם” — אבל מי שמנה אותו קיבל דגל. **תמיד מְנָה כל פורט פתוח.**

🎯 **מה קרה כאן:** שירות רשת לרוב “מציג את עצמו” ב-Banner מיד עם החיבור. הגרסה המדויקת (vsFTPD 2.3.4) היא המפתח — בסעיף 6.8 נחפש לה Exploit.

🧠 **בדוק את עצמך:** מהו “Banner Grabbing” (א - חסימת פורט - ב) התחברות לשירות וקריאת המידע (כולל גרסה) שהוא מציג - ג) הצפנת התעבורה

✅ **תשובה: ב** — מתחברים לפורט וקוראים את ה-Banner שהשירות שולח; הוא מסגיר לרוב את סוג השירות וגרסתו המדויקת.

NSE — Nmap Scripting Engine

```
nmap --script vuln 192.168.56.10      # חיפוש חולשות ידועות
nmap --script smb-enum-shares 192.168.56.10
nmap -p 445 --script smb-vuln-ms17-010 192.168.56.10  # בדיקת EternalBlue
```

הסקריפטים ב- `/usr/share/nmap/scripts/`.

שמירת פלט

```
nmap -sC -sV -oA fullscan 192.168.56.10  # -oA = כל הפורמטים (.nmap/.gnmap/.xml)
```

6.4 מניית HTTP/HTTPS

אם פורט 80/443 פתוח — יש שרת web. זהו לרוב משטח התקיפה הגדול ביותר.

```
whatweb http://192.168.56.10      # זיהוי טכנולוגיות
nikto -h http://192.168.56.10     # נפוצות web סורק חולשות
```

גילוי ספריות וקבצים נסתרים (Directory Brute-Force)

```
gobuster dir -u http://192.168.56.10 -w /usr/share/wordlists/dirb/common.txt
# חלופות:
dirb http://192.168.56.10
feroxbuster -u http://192.168.56.10
```

מחפש נתיבים נסתרים כמו `/robots.txt` , `/config` , `/backup` , `/admin`

בדיקה ידנית

- גלוש לאתר, קרא את קוד המקור (Ctrl+U), חפש הערות ונתיבים.
- בדוק את `/robots.txt` ו- `/sitemap.xml`.
- זוהה את גרסת שרת ה- Web (Header Server:) — יעד לחיפוש Exploit.

💡 **HTTP מול HTTPS:** בדוק את **שניהם** (80 ו-443) — לעיתים הם מגישים תוכן שונה, ו-HTTPS עשוי לחשוף פרטים בתעודת ה-SSL (שמות דומיין, מיילים).

🎬 הדגמה — נסה בעצמך: מנה שרת web וגלה נתיב נסתר 🚩

נשתמש באתר ACME ממודול 5 כמטרה, ונמצא נתיב ניהול שלא מקושר בשום מקום.

צעד 1 — טרמינל 1: הפעל את אתר המטרה:

```
python3 ../05-recon/recon_target.py # http://127.0.0.1:8000
```

צעד 2 — בדיקה ידנית מהירה — קרא את `robots.txt`:

```
curl -s 127.0.0.1:8000/robots.txt
```

👁️ `Disallow: /admin-panel/` — robots הסגיר נתיב מוסתר.

צעד 3 — Directory Brute-Force אוטומטי (מגלה נתיבים גם בלי robots):

```
gobuster dir -u http://127.0.0.1:8000 -w /usr/share/wordlists/dirb/common.txt
```

👁️ gobuster מוצא נתיבים כמו `/admin-panel` ו- `/backup` (סטטוס 200). אין gobuster? הבדיקה הידנית לעיל מספיקה.

```
curl -s 127.0.0.1:8000/admin-panel/
```

👁 פאנל ניהול חשוף — דגל בפנים.

🎯 **מה קרה כאן:** Directory Brute-Force מנחש שמות נתיבים נפוצים ומגלה דפים "מוסתרים" שאינם מקושרים. זה משלב את איסוף המידע (מודול 5) עם מנייה אקטיבית.

🧠 **בדוק את עצמך:** מה עושה `gobuster dir` - ? (א) מנחש שמות של נתיבים/קבצים באתר לפי רשימת מילים, ומדווח אילו קיימים - (ב) מפיל את השרת - (ג) מפענח סיסמאות

✅ **תשובה: א** — הוא שולח בקשות לנתיבים מרשימה (wordlist) ומזהה לפי קוד התגובה אילו קיימים — מגלה דפי ניהול/גיבוי מוסתרים.

6.5 מניית SMB

SMB (Server Message Block) — פרוטוקול שיתוף קבצים של Windows, על פורטים **139/445**. נפוץ מאוד ברשתות פנימיות, ומקור לחולשות חמורות.

```
enum4linux -a 192.168.56.10      # מנייה מקיפה (משתמשים, שיתופים, קבוצות)
smbclient -L //192.168.56.10/    # רשימת שיתופים (Shares)
smbclient //192.168.56.10/share  # התחברות לשיתוף
nmap -p 139,445 --script smb-enum-shares,smb-enum-users 192.168.56.10
```

חולשות SMB מפורסמות

• **MS17-010 (EternalBlue)** — חולשה קריטית ששימשה במתקפת **WannaCry**. עדיין נמצאת במערכות רבות.

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.56.10
```

• **SMB Null Session** — התחברות ללא אימות, חושפת משתמשים ושיתופים.

🔍 כשאתה רואה SMB בסריקה — **חשוב "רשת פנימית ארגונית"**. זהו אחד הווקטורים המרכזיים לתנועה רוחבית (מודול 12) ו-Active Directory (מודול 13).

6.6 מניית SSH ו-FTP

SSH (פורט 22)

```
nmap -p 22 -sV 192.168.56.10      # גרסת OpenSSH
ssh user@192.168.56.10          # ניסיון התחברות
```

גרסה ישנה = חולשה אפשרית. SSH הוא גם יעד מרכזי ל-**Brute Force** (מודול 8).

FTP (פורט 21)

```
nmap -p 21 -sV --script ftp-anon 192.168.56.10  # בדיקת התחברות אנונימית
ftp 192.168.56.10                                # user: anonymous נסה
```

• **Anonymous FTP** — אם מאופשר, מאפשר גישה לקבצים ללא סיסמה — פרס נפוץ.

6.7 סריקת חולשות עם Nessus

Nessus הוא סורק חולשות אוטומטי (מבית Tenable) — מזהה אלפי חולשות ידועות ומדרג אותן לפי חומרה. הגרסה **Nessus Essentials** חינמית (עד 16 כתובות IP).

התקנה והרצה

1. מ-tenable.com - הורד את חבילת ה- .deb
2. `sudo dpkg -i Nessus-*.deb`
3. `sudo systemctl start nessusd`
4. Essentials צור חשבון ← `https://localhost:8834` - גלוש ל
5. Launch → של היעד IP- הזן את ה → New Scan → Basic Network Scan

קריאת התוצאות

Nessus מדרג ממצאים: **Info / Low / Medium / High / Critical**, כל אחד עם תיאור, CVE, ותיקון מומלץ.

⚠ חשוב: Nessus הוא כלי **רועש** — הוא שולח הרבה תעבורה. הרץ רק על יעדים מורשים, ואל תסתמך עליו לבד — סריקה אוטומטית מפספסת חולשות לוגיות שרק מנייה ידנית תמצא.

6.8 חקר חולשות (Searchsploit / Exploit-DB)

מצאת שירות בגרסה מסוימת — עכשיו מחפשים אם יש לו Exploit ידוע.

```
searchsploit apache 1.3.20      # Exploit-DB חיפוש מקומי במאגר
searchsploit -m 764             # לתיקיה הנוכחית Exploit העתקת
searchsploit openssh 2.9
```

• **Exploit-DB** (exploit-db.com) — מאגר ה-Exploits הגדול; `searchsploit` הוא העותק המקומי ב-Kali.

• **CVE** (Common Vulnerabilities and Exposures) — מזהה ייחודי לכל חולשה (למשל CVE-2017-0144 = EternalBlue). חפש ב-cve.mitre.org או nvd.nist.gov.

🔍 **הזרימה המלאה:** `searchsploit apache 1.3.20` → `nmap -sV` מגלה `Apache 1.3.20` → מוצא Exploit → נשמור אותו לשלב הניצול (מודול 7). זהו הגשר בין מנייה לניצול.

🎬 הדגמה — נסה בעצמך: מגרסה ל-Exploit

מצאנו `vsftpd 2.3.4` בסריקה. עכשיו נבדוק אם יש לו חולשה ידועה — זה הגשר לניצול.

צעד 1 — חפש את הגרסה במאגר ה-Exploits המקומי:

```
searchsploit vsftpd 2.3.4
```

👁️ תוצאה: `Backdoor Command Execution - vsftpd 2.3.4`. הגרסה הזו מכילה **דלת אחורית מפורסמת** — מי שמתחבר עם שם משתמש שמסתיים ב- (:) פותח shell בפורט 6200!

צעד 2 — חפש עוד גרסאות שמצאנו:

```
searchsploit openssh 2.9
searchsploit apache 1.3.20
```

👁️ כל גרסה ישנה = רשימת חולשות אפשריות.

צעד 3 — קרא את פרטי ה-Exploit (הנתיב מופיע בעמודה הימנית של הפלט מצעד 1):

```
searchsploit -p unix/remote/49757.py # -p (החלף במספר שקיבלת)
# להעתקה לתיקיה הנוכחית לצורך עיון/הרצה
searchsploit -m unix/remote/49757.py
```

👁️ כל Exploit מגיע עם קובץ, תיאור, ולעיתים CVE — זה מה שנעביר לשלב הניצול (מודול 7).

🎯 **מה קרה כאן:** חיברת גרסה מדויקת (מ-Banner Grabbing) → **Exploit ידוע** (מ-searchsploit). זו בדיוק שרשרת ההיגיון של בודק חדירות: מְנָה → חקור → נצל.

🧠 **בדוק את עצמך:** מה מספק `searchsploit apache 1.3.20` ? - א) מפעיל אוטומטית Exploit על היעד - ב) מחפש במאגר Exploit-DB המקומי חולשות ידועות לגרסה הזו - ג) מעדכן את Apache

✅ **תשובה: ב** — `searchsploit` הוא חיפוש מקומי במאגר Exploit-DB. הוא רק מוצא/מציג — ההרצה בפועל היא שלב הניצול (מודול 7).

6.9 ארגון הערות

בבדיקה אמיתית תצבור מידע רב. **תיעוד מסודר הוא קריטי** — גם לניצול, גם לדוח הסופי (מודול 16).

- כלים: **CherryTree**, **Obsidian**, **Joplin**, או פשוט תיקיית Markdown.
- מבנה מומלץ לכל יעד: IP → פורטים פתוחים → שירותים וגרסאות → ממצאי מנייה → חולשות אפשריות → פקודות שהרצת.
- **צלם מסך** של כל ממצא חשוב — תזדקק לזה לדוח.

💡 **הרגל מקצועי:** פתח קובץ הערות לכל יעד **לפני** שאתה מתחיל, והדבק אליו כל פלט תוך כדי. עדיף מדי-מפורט מאשר לשכוח איך הגעת לממצא.

סיכום המודול

- **Nmap** הוא הליבה: `-sn` לגילוי מארחים, `-p- -sV -sC` למנייה מלאה, `--script` ל-NSE.
- **מנייה לפי שירות:** HTTP (nikto, gobuster), SMB (enum4linux, smbclient, MS17-010), SSH/FTP (anonymous, גרסאות).
- **Nessus** לסריקת חולשות אוטומטית — כלי עזר, לא תחליף למנייה ידנית.
- **Searchsploit / Exploit-DB / CVE** מגשרים בין גרסה שנמצאה ל-Exploit — הכניסה לשלב הניצול.
- **תעד הכל** — לניצול ולדוח.

מה הלאה?

➡ **תרגילים** — `missions.md` • פתרונות — `solutions.md` • תרגול ותרחישים — `practice.md` ➡
מודול 7 — ניצול והשגת גישה

